

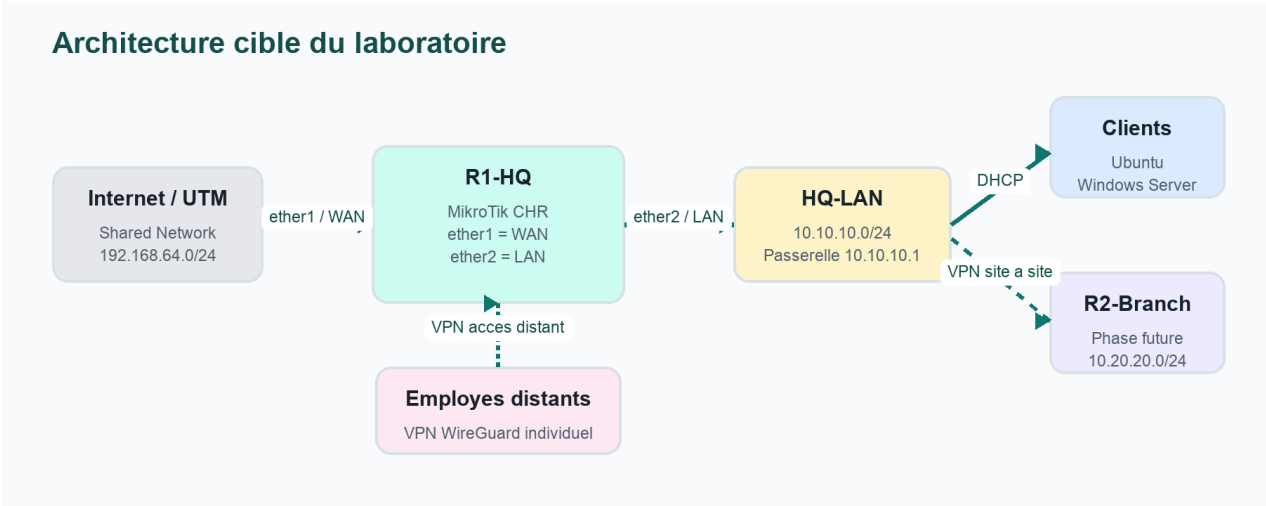
CAHIER DES CHARGES

Mise en place d'un firewall MikroTik et de VPN securises

Laboratoire virtualise sous UTM sur Apple Silicon

Finalite du projet

Construire une plateforme de securite reseau permettant de filtrer le trafic du siege, de relier deux routeurs et de donner aux employes un acces distant chiffre et controle.



Champ	Valeur
Projet	Firewall et VPN MikroTik CHR
Routeur principal	R1-HQ
Plateforme	UTM / QEMU / Apple Silicon
Version du document	1.0
Date	17 juillet 2026
Statut	Etapes 1 et 2 terminees - Etape 3 en cours

Synthese executive

Vision, perimetre et etat actuel du projet

Decision d'architecture

R1-HQ est place entre un cote WAN non fiable et un reseau interne HQ-LAN. Tout acces Internet des clients doit traverser le MikroTik. Les acces distants et la future liaison avec R2-Branch utiliseront WireGuard.

1. Contexte et besoin

L'entreprise souhaite disposer d'un firewall capable de controler les connexions entre Internet, le reseau du siege et un futur site distant. Le point le plus important concerne les employes qui doivent se connecter depuis l'exterieur sans exposer directement les services internes.

Le projet est d'abord construit dans un laboratoire UTM afin de tester chaque regle avant une presentation ou un deploiement reel. Cette methode reduit le risque de coupure, de perte d'accès administratif ou de regle trop permissive.

2. Objectifs generaux

- Creer un routeur/firewall principal R1-HQ sous MikroTik CHR.
- Separer clairement le WAN, le LAN du siege et les futurs reseaux distants.
- Fournir DHCP, DNS et NAT aux machines du reseau interne.
- Mettre en oeuvre une politique de firewall restrictive et testable.
- Deployer un VPN WireGuard pour les employes distants.
- Preparer un VPN site a site entre R1-HQ et un futur R2-Branch.
- Tester le comportement avec Ubuntu, Windows Server, pfSense et des outils de diagnostic.
- Documenter les configurations, sauvegardes, tests et preuves de fonctionnement.

3. Perimetre

3.1 Inclus dans le projet

- Virtualisation UTM sur Mac Apple Silicon.
- MikroTik CHR ARM64 comme routeur et firewall.
- Reseaux virtuels WAN, HQ-LAN et futur BRANCH-LAN.
- Services DHCP, DNS, NAT, firewall, journalisation et VPN.
- Machines clientes de test et scenarios d'acceptation.
- Backups RouterOS et documentation technique.

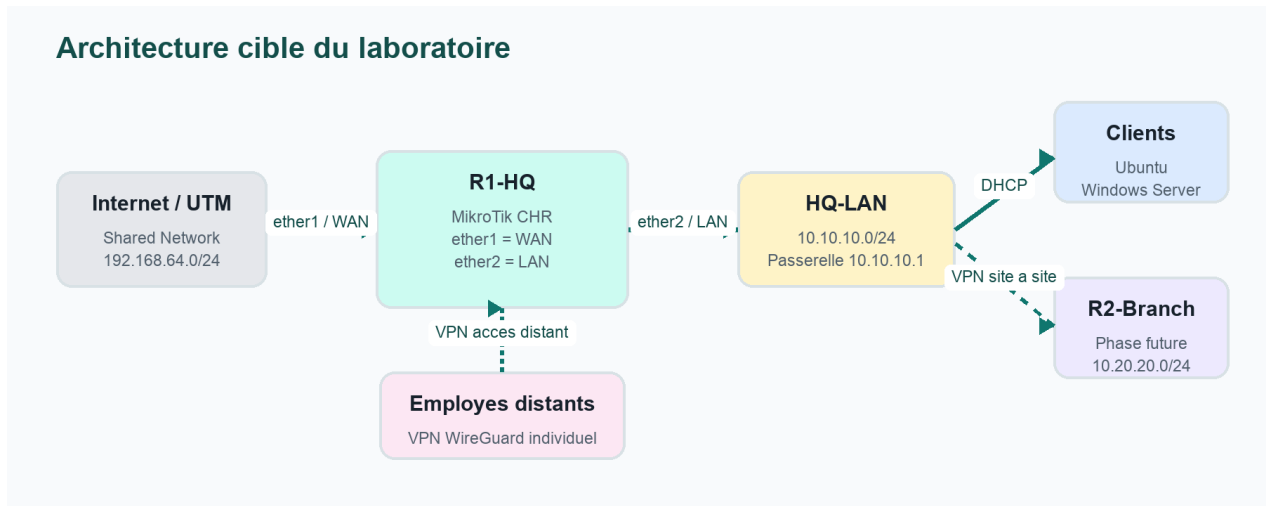
3.2 Hors perimetre actuel

- Deploiement direct sur le reseau de production de l'entreprise.
- Achat de routeurs physiques, licences commerciales ou certificats publics.
- Haute disponibilite avec deux firewalls actifs/passifs.
- Authentification multifacteur native WireGuard; une solution RADIUS/IdP complementaire devra etre etudiee si le MFA est obligatoire.

Architecture et exigences

Description technique de la cible

4. Architecture cible



Le trafic suit la chaine suivante : client interne -> ether2 -> R1-HQ -> controles firewall/NAT -> ether1 -> Internet. Les connexions entrantes du WAN sont refusees par default, sauf les services explicitement autorises, notamment le port du VPN.

5. Plan d'adressage

Zone	Reseau / adresse	Passerelle	Usage
WAN UTM	192.168.64.0/24	192.168.64.1	Acces externe du laboratoire
R1-HQ WAN	192.168.64.2	192.168.64.1	WebFig et sortie Internet
HQ-LAN	10.10.10.0/24	10.10.10.1	Reseau du siege
Pool DHCP HQ	10.10.10.100-200	10.10.10.1	Postes clients dynamiques
Ubuntu test	10.10.10.200/24	10.10.10.1	Client obtenu par DHCP
BRANCH-LAN	10.20.20.0/24	10.20.20.1	Phase future R2-Branch
VPN employes	10.99.0.0/24	R1-HQ	Adresses WireGuard proposees

6. Exigences fonctionnelles

ID	Exigence
F-01	R1-HQ doit router le trafic entre HQ-LAN et le WAN.

ID	Exigence
F-02	Les clients HQ-LAN doivent recevoir automatiquement une adresse, une passerelle et un DNS.
F-03	Le NAT doit traduire uniquement le trafic sortant autorise de 10.10.10.0/24.
F-04	Le firewall doit refuser les connexions entrantes non sollicitees depuis le WAN.
F-05	L'administration du routeur doit etre limitee aux reseaux autorises.
F-06	Chaque employe distant doit disposer de son propre pair WireGuard et de sa propre cle.
F-07	R1-HQ et R2-Branch doivent echanger uniquement les sous-reseaux approuves via un tunnel site a site.
F-08	Les journaux doivent permettre d'identifier les connexions refusees importantes sans saturer le routeur.
F-09	Une sauvegarde doit etre creee avant et apres chaque changement majeur.

7. Exigences de securite

- Politique par default restrictive : autoriser ce qui est necessaire, refuser le reste.
- Regles basees sur les etats de connexion : established/related autorises, invalid refuses.
- Aucun service d'administration expose inutilement sur le WAN.
- Telnet, FTP, API, API-SSL et Reverse Proxy desactives tant qu'ils ne sont pas justifies.
- WebFig, SSH et WinBox conservees pour l'administration, puis limitees au LAN/VPN.
- Cles WireGuard individuelles, revocables et non partagees entre employes.
- Principe du moindre privilege pour l'acces VPN aux serveurs internes.
- Backups conservees hors du routeur et mots de passe non inclus dans les rapports.

Dossier de realisation

Travaux executes depuis la creation du laboratoire

8. Etape 0 - Creation de la VM MikroTik CHR

Une nouvelle VM QEMU nommee MikroTik CHR Automated a ete creee dans /Applications/UTM.app sans modifier ni supprimer les autres machines UTM existantes. Le disque ARM64 officiel chr-7.22.1-arm64.qcow2 a ete verifie avant import afin d'eviter la creation accidentelle d'un disque vide.

Parametre	Configuration
Architecture	aarch64 / ARM64
Machine QEMU	virt ARM virtual machine
Memoire	2048 MiB
CPU	2 coeurs
Acceleration	Apple Hypervisor active si supporte
Demarrage	UEFI
Affichage / son	Aucun affichage graphique, aucun son
Console	Une console serie PTTY
WAN initial	Shared Network, virtio-net-pci
Disque	Image MikroTik ARM64 importee comme VirtIO non amovible

9. Etape 1 - Preparation et securisation de R1-HQ

- Connexion WebFig a <http://192.168.64.2>.
- Renommage du routeur MikroTik vers R1-HQ : R1 pour routeur principal, HQ pour Headquarters.
- Creation du backup R1-HQ-baseline.backup avant les changements.
- Desactivation de Telnet, FTP, API, API-SSL et Reverse Proxy.
- Conservation de WebFig, SSH et WinBox pour l'administration.
- Creation du backup R1-HQ-step1-secured.backup apres durcissement.

Pourquoi le firewall a ete reporte

A ce moment, le routeur ne possedait que ether1. Il fallait d'abord creer ether2 pour differencier sans ambiguïte le WAN non fiable du LAN interne et eviter de bloquer WebFig.

10. Etape 2 - Creation du LAN du siege

- Arret propre de R1-HQ avant modification du materiel virtuel.
- Creation du Host Network UTM HQ-LAN.
- Ajout d'une seconde carte virtio-net-pci en mode macOS Host Only.
- Association de ether2 au reseau HQ-LAN.
- Attribution de 10.10.10.1/24 a ether2 avec le commentaire HQ LAN Gateway.
- Creation du pool DHCP 10.10.10.100-10.10.10.200.
- Configuration du reseau DHCP 10.10.10.0/24 et de la passerelle 10.10.10.1.

Incident Safe Mode

Le message setup failed to enter safe mode: safe mode already held by somebody (8) provenait d'un Safe Mode deja actif dans WebFig. La solution etait de liberer ce mode avant de relancer DHCP Setup.

11. Etape 3 - NAT, DNS et client Ubuntu

Cette etape valide que R1-HQ est reellement place sur le chemin du trafic et qu'un client du LAN peut utiliser ses services.

Element	Valeur / resultat	Statut
Regle NAT	srcnat masquerade, source 10.10.10.0/24, sortie ether1	Valide
Compteurs observes	115.7 KiB et 1 532 paquets au moment du controle	Preuve de passage
DNS MikroTik	Allow Remote Requests active	Valide
DNS distribue	10.10.10.1 via DHCP	Valide
VM cliente	HQ-Test-Client, Ubuntu Server ARM64	Creee
Disque client	20 Go VirtIO, nouvelle VM uniquement	Pret
Adresse Ubuntu	10.10.10.200/24 par DHCP	Valide
Miroir Ubuntu	ma.ports.ubuntu.com, test reussi	Valide
Telechargement test	508 kB, environ 135 kB/s	Valide
Installation Ubuntu	Ecran Guided storage atteint, ecriture disque en attente d'approbation	En cours

Politique firewall et VPN

Regles cibles a implementer et a tester

12. Politique de filtrage cible

12.1 Chaine input - protection du routeur

Ordre	Action	Condition	But
1	Accept	established, related	Maintenir les connexions legitimes
2	Drop	invalid	Refuser les paquets incoherents
3	Accept	ICMP limite	Diagnostic sans abus
4	Accept	HQ-LAN -> administration	WebFig, SSH et WinBox depuis le LAN
5	Accept	VPN WireGuard depuis WAN	Autoriser uniquement le port du tunnel
6	Drop	tout le reste depuis WAN	Politique restrictive

12.2 Chaine forward - protection des reseaux

Ordre	Action	Condition	But
1	Accept	established, related	Reponses aux connexions autorisees
2	Drop	invalid	Trafic invalide
3	Accept	HQ-LAN -> WAN	Internet pour le siege
4	Accept limite	VPN employes -> serveurs autorises	Moindre privilege
5	Accept	HQ-LAN <-> BRANCH-LAN	Uniquement via WireGuard site a site
6	Drop	WAN -> LAN non sollicite	Bloquer les connexions entrantes
7	Drop	tout le reste	Fin de politique explicite

13. VPN d'accès distant pour les employés

- Technologie recommandée : WireGuard pour sa simplicité, ses performances et sa cryptographie moderne.
- Une clé privée et une adresse VPN uniques par employé; aucune clé partagée.
- Le pare-feu autorise chaque groupe d'employés uniquement vers les ressources nécessaires.
- Un pair peut être désactivé immédiatement en cas de départ, perte de poste ou suspicion.
- Les configurations clientes sont transmises par un canal sécurisé et ne sont jamais publiées dans le rapport.
- Le MFA n'est pas fourni nativement par WireGuard; si l'entreprise l'exige, ajouter une passerelle d'identité/RADIUS ou une solution VPN avec authentification forte.

14. VPN site à site R1-HQ - R2-Branch

1. Créer R2-Branch dans une VM séparée sans réutiliser les disques de R1-HQ.
2. Configurer BRANCH-LAN en 10.20.20.0/24 avec la passerelle 10.20.20.1.
3. Créer un tunnel WireGuard dédié entre les deux routeurs.
4. Limiter Allowed Address aux réseaux 10.10.10.0/24 et 10.20.20.0/24.
5. Ajouter les routes et règles forward nécessaires, sans NAT entre les deux LAN.
6. Tester ping, DNS, accès aux services autorisés et blocage des services interdits.

Tests, livrables et planning

Conditions de validation du projet

15. Plan de tests

ID	Test	Critere d'acceptation
T-01	DHCP	Le client recoit une adresse 10.10.10.100-200, gateway 10.10.10.1 et DNS 10.10.10.1.
T-02	Passerelle	Le client joint 10.10.10.1.
T-03	Internet	Le client joint une adresse Internet et le compteur NAT augmente.
T-04	DNS	Le client resout un nom public via R1-HQ.
T-05	WAN vers LAN	Une connexion non sollicitee depuis le WAN est bloquee.
T-06	Administration	WebFig/SSH/WinBox sont accessibles depuis le LAN ou VPN autorise et bloque ailleurs.
T-07	VPN employe	Un pair valide rejoint uniquement les ressources autorisees.
T-08	Revocation	Un pair desactive ne peut plus se connecter.
T-09	Site a site	HQ-LAN et BRANCH-LAN communiquent uniquement selon la matrice d'accès.
T-10	Journalisation	Les refus importants sont visibles sans flood excessif des logs.
T-11	Restauration	Un backup RouterOS peut restaurer l'etape correspondante.

16. Livrables

- VM MikroTik CHR Automated configuree comme R1-HQ.
- VM cliente HQ-Test-Client sous Ubuntu Server.
- Backups R1-HQ-baseline.backup, R1-HQ-step1-secured.backup et R1-HQ-step2-LAN.backup.
- Backups supplementaires apres NAT, firewall et VPN.
- Fichiers Etape 1, Etape 2, cahier des charges et futur rapport de stage.
- Plan d'adressage, matrice firewall, inventaire des peers VPN sans cles privees.
- Captures et resultats de tests prouvant le fonctionnement et le blocage attendu.

17. Planning de realisation sur 8 jours

Periode	Travaux	Etat
Jour 1	VM CHR, identification R1-HQ, backups, services inutiles desactives	Termine
Jour 2	HQ-LAN, ether2, adressage, DHCP	Termine
Jour 3	NAT, DNS local, VM Ubuntu, validation Internet	En cours
Jour 4	Installation Ubuntu, firewall input et tests de non-regression	A faire
Jour 5	Firewall forward, logs, tests autorise/refuse	A faire
Jour 6	WireGuard employes, pairs individuels, revocation	A faire
Jour 7	R2-Branch, VPN site a site, Windows Server/pfSense	A faire
Jour 8	Tests finaux, backups, captures, presentation et rapport	A faire

18. Risques et mesures de reduction

Risque	Impact	Mesure
Blocage de WebFig	Eleve	Safe Mode, acces serie, backup avant les regles drop.
Confusion WAN/LAN	Eleve	Noms explicites ether1-WAN et ether2-LAN, interface lists.
Regle trop permissive	Eleve	Tests par cas, principe du moindre privilege, drop final.
Perte de cle VPN	Eleve	Peer individuel, revocation immediate, inventaire controle.
DNS indisponible	Moyen	R1-HQ comme resolver LAN, test DNS separe du ping IP.
Echec VM ou disque	Moyen	Images verifiees, backups UTM/RouterOS, aucun disque vide cree.
Journalisation excessive	Moyen	Rate limit et journalisation ciblee.

19. Criteres de recette finale

- R1-HQ démarre de manière fiable et conserve sa configuration.
- Un client HQ-LAN obtient automatiquement sa configuration réseau.
- Internet et DNS fonctionnent uniquement en passant par R1-HQ.
- Les connexions WAN non autorisées sont bloquées.
- L'administration est limitée aux sources autorisées.
- Un employé distant autorisé atteint uniquement les services prévus.
- Un pair VPN révoqué est effectivement bloqué.
- La liaison R1-HQ/R2-Branch respecte la matrice des flux.
- Les backups, configurations et preuves de test sont disponibles.

Etat a la date du document

Les fondations réseau sont opérationnelles et les tests DHCP/DNS/NAT ont réussi. L'installation Ubuntu est arrivée à l'écran de partitionnement du disque de la nouvelle VM; elle reste à confirmer avant de poursuivre vers le firewall et WireGuard.